06 · LOT API Connector: Device ↔ lot-systems.com

Doc: LOT-HW-01-API · **Rev:** A (2026-11-14) · **Status:** specification. The server routes are *not yet implemented* (roadmap phase 1).

1. WHY A NEW NAMESPACE

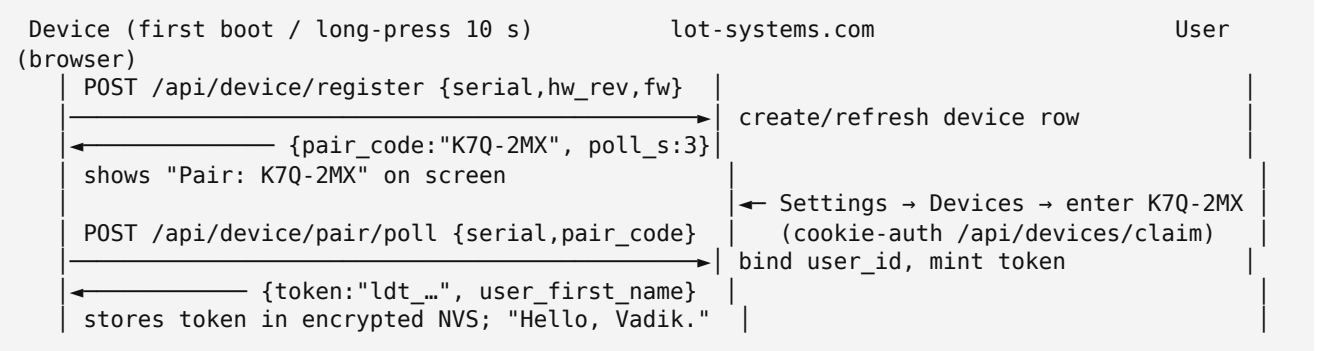
The site authenticates browsers with a JWT in a cookie plus a `Session` row (`src/server/server.ts`, the `onRequest` hook). A device cannot do the email-code login. It needs a long-lived, revocable, per-device token that is scoped to the device endpoints only. The device must never hold a full user session.

New prefix: **`/api/device/*`**, registered beside `/api/public` with its own auth hook.

2. DATA MODEL (NEW MIGRATION)

```
        CREATE TABLE devices (
          id            UUID PRIMARY KEY,
          user_id       UUID REFERENCES users(id) ON DELETE CASCADE,  -- NULL until paired
          serial        TEXT UNIQUE NOT NULL,           -- "LT01-000042", burned at factory test
          hw_rev        TEXT NOT NULL,                  -- "EVT1"
          fw_version    TEXT,
          token_hash    TEXT,                           -- sha256(device token). The raw token is never stored
          pair_code     TEXT,                           -- 6 chars, Crockford base32, 10-min TTL
          pair_expires  TIMESTAMPTZ,
          last_seen_at  TIMESTAMPTZ,
          battery_pct   SMALLINT,
          settings      JSONB DEFAULT '{}',             -- quiet hours, cadence, haptic strength
          created_at    TIMESTAMPTZ, updated_at TIMESTAMPTZ
        );
        CREATE TABLE device_notifications (
          id           UUID PRIMARY KEY,
          device_id    UUID REFERENCES devices(id) ON DELETE CASCADE,
          user_id      UUID REFERENCES users(id) ON DELETE CASCADE,
          text         VARCHAR(48) NOT NULL,           -- pager line, already compressed
          kind         TEXT NOT NULL,                  -- 'nudge' | 'checkin' | 'weather' | 'system'
          source       JSONB DEFAULT '{}',             -- which engine/prompt produced it
          delivered_at TIMESTAMPTZ, copied_at TIMESTAMPTZ,
          created_at   TIMESTAMPTZ
        );
        CREATE INDEX ON device_notifications (device_id, delivered_at);
```

3. PAIRING (DEVICE-CODE FLOW)



- Token format: `ldt_` + 32 random bytes in base64url. The server stores only `sha256(token)`.
- Revoke from Settings → Devices. Every later device call then gets `401`, and the device returns to pairing.
- Rate limits: register 5/h per IP, poll 1/2 s per serial, claim 10/h per user.

4. ENDPOINTS

All requests use `Authorization: Bearer ldt_…` (except register and pair/poll) and `Content-Type: application/json`. Bodies are ≤ 512 B, except the photo upload.

Method	Path	Body → Response	Purpose
POST	`/api/device/register`	`{serial,hw_rev,fw}` → `{pair_code,expires_s,poll_s}`	Start pairing
POST	`/api/device/pair/poll`	`{serial,pair_code}` → `{status:"pending"}` or `{token,name}`	Finish pairing
POST	`/api/devices/claim` (cookie auth)	`{pair_code}` → `{device}`	User binds the device in the browser
GET	`/api/device/sync?since=<cursor>`	→ `{n:[{id,t,k,ts}],cur,next_poll_s,cfg?}`	**The main call.** Pending notifications plus config. Marks them delivered
POST	`/api/device/copy`	`{nid,ts}` → `{log_id}`	**Copy button.** Writes a Log entry
POST	`/api/device/photo`	raw `image/jpeg` body (≤ 60 KB) + header `X-LOT-Notification: <nid>` → `{log_id}`	Long-press Copy. Attaches a photo (no multipart encoder needed on the device)
POST	`/api/device/telemetry`	`{tc,rh,hpa,iaq,gc,lux,bat,rssi}` → `{ok}`	Weather/sensor upload every 15 min
POST	`/api/device/ota/check`	`{fw}` → `{url,sha256,size,sig}` or `{}`	Firmware update

Short keys in `sync`: `t` text, `k` kind, `ts` unix seconds. This keeps responses inside one TLS record.

5. COPY → LOG TAB (REQUIREMENT 16)

`POST /api/device/copy {nid}` does the following on the server:

```
        await fastify.models.Log.create({
          userId: device.userId,
          event: 'device_copy',
          text: notification.text,                        // "Coffee time!"
          metadata: { deviceId: device.id, serial: device.serial, notificationId: nid, kind:
notification.kind },
          context: { source: 'lot-tile', copiedAt: new Date().toISOString(), weather:
lastTelemetry },
        })
```

Two code changes are required so the entry *appears* in the Log tab:

1. Add `'device_copy'` (and `'device_photo'`) to the `LogEvent` union in `src/shared/types/index.ts`.
2. Add both to the `displayableEvents` allow-list in `GET /api/logs` (`src/server/routes/api.ts`, around line 1084). Without this the entry is stored but filtered out of the tab.

Client rendering: show it as a normal Log row with a small `TILE` label in tertiary opacity, matching the LOT style guide.

6. WHERE NOTIFICATIONS COME FROM: THE "AI-POWERED SITE"

A new scheduled job (`src/server/scheduled-jobs.ts`) named **`device-nudge`** runs every 5 minutes for users with a paired device:

1. Gather context the site already computes: local time and circadian phase, Memory Engine answers (for example the morning-beverage answer "Coffee" in `src/server/utils/memory/constants.ts`), recent Log activity, weather, and the latest BME688 telemetry.
2. Decide whether a nudge is due (deterministic rules first, such as "morning beverage window, nothing logged yet"). Call Claude only for wording.
3. **Compress to a pager line**, ≤ 48 characters, in LOT voice: a sentence ending in a period or "!", no emoji. Validate on the server and truncate on a word boundary.
4. Enforce quiet hours, a cap of 8 per day, and a minimum gap of 45 minutes. Insert into `device_notifications`.

Example outputs: `Coffee time!` · `Walk. 12°C, clear.` · `Evening check-in.` · `Air is stale. Open a window.`

7. COMPRESSION (REQUIREMENT 8)

Layer	What is compressed	How
AI → line	Full user context (KBs)	Condensed into one 48-character line on the server
Wire	JSON payloads	Short keys, deltas only (a `since` cursor), ≤ 512 B. No base64 except the photo
Photo	VGA frame	On-device JPEG at q≈12, 320 × 240, ≤ 60 KB
Telemetry	15-min samples	Batched when offline, as a ring buffer of 96 samples (24 h). Sent as one array on reconnect
Session knowledge	Each work session on this project	A "Compressed ledger" block at the end of every session report

8. SECURITY

- TLS 1.2+ only, with the ISRG Root X1 and X2 anchors pinned in firmware (lot-systems.com uses Caddy/Let's Encrypt; see `Caddyfile`).
- The device token lives in NVS encrypted with the flash-encryption key. Secure Boot v2 is enabled at PVT.
- Device endpoints can never read user data beyond its own notifications. They can only write Log rows of type `device_*`.
- OTA images are signed (ECDSA P-256), and the signature is checked before switching boot partitions.
